

BOOT2ROOT

Apa itu Boot2Root?

Boot2Root adalah latihan keamanan siber yang mensimulasikan proses kompromi sebuah sistem dari awal hingga mendapatkan akses **root/administrator**. Biasanya digunakan dalam:

- Capture The Flag (CTF)
- Pelatihan Ethical Hacking
- Penetration Testing Lab
- Red Team Exercise

Tujuan utamanya:

1. Enumerasi target
2. Eksploitasi layanan
3. Privilege escalation
4. Persistence
5. Post-exploitation

Tahapan Umum Boot2Root

1. Information Gathering & Reconnaissance

Tahap awal untuk mengumpulkan informasi target.

Rekomendasi Teknik

- Network Scanning
- Service Enumeration
- OS Fingerprinting
- Directory Bruteforce
- Subdomain Enumeration
- Banner Grabbing

Tools

- Nmap
- Netcat

- Gobuster
- Dirsearch
- Wireshark
- WhatWeb

Contoh

`nmap -sC -sV -A 192.168.1.10`

2. Enumeration

Tahap paling penting dalam Boot2Root.

Service Enumeration

SSH

- Weak credentials
- Misconfigured keys
- Old OpenSSH vulnerabilities

FTP

- Anonymous login
- Writable directory
- Credential leakage

SMB

- Null session
- SMB shares
- SMB signing disabled

HTTP/HTTPS

- Hidden directories
- CMS vulnerabilities
- File upload bypass
- LFI/RFI
- SQL Injection
- Command Injection

Database

- Default credentials

- Exposed services
- Weak permissions

3. Web Exploitation

Common Vulnerabilities

SQL Injection

- Authentication bypass
- Database dumping
- Remote command execution

Local File Inclusion (LFI)

?page=../../../../etc/passwd

Remote File Inclusion (RFI)

Command Injection

127.0.0.1; whoami

File Upload Bypass

- Double extension
- MIME type bypass
- Web shell upload

XSS

- Stored
- Reflected
- DOM-based

4. Credential Attacks

Password Attacks

Wordlists

- rockyou.txt
- custom lists

Tools

- Hydra
- John the Ripper

- Hashcat

Password Spraying

Brute Force

Credential Stuffing

5. Binary Exploitation

Stack Buffer Overflow

Konsep:

- Overwrite EIP/RIP
- Shellcode injection
- Return address manipulation

Heap Exploitation

- Use-After-Free
- Double Free
- Heap Overflow

Format String Vulnerability

`printf(user_input);`

Integer Overflow

Race Condition

Tools

- GDB
- pwntbg
- GEF
- Pwntools

6. Linux Privilege Escalation

SUID Binary Abuse

Cari:

`find / -perm -4000 2>/dev/null`

Misconfigured sudo

`sudo -l`

Kernel Exploits

- Dirty COW
- PwnKit
- OverlayFS

Cron Jobs

- Writable scripts
- PATH hijacking

PATH Hijacking

Weak File Permissions

Capabilities Abuse

`getcap -r / 2>/dev/null`

Enumeration Tools

- LinPEAS
- LinEnum
- Linux Exploit Suggester

7. Windows Privilege Escalation

Common Vectors

- Unquoted service path
- Weak service permissions
- AlwaysInstallElevated
- DLL hijacking
- Token impersonation

Active Directory Abuse

- Kerberoasting
- Pass-the-Hash
- AS-REP Roasting
- Golden Ticket

Tools

- WinPEAS
- BloodHound

- Mimikatz

8. Wireless Exploitation

WiFi Attacks

- WPA/WPA2 handshake capture
- Evil Twin
- Rogue AP
- Deauthentication attack

Tools

- Aircrack-ng
- Kismet

9. Container & Cloud Exploitation

Docker Escapes

- Privileged containers
- Docker socket abuse
- Mounted filesystem

Kubernetes

- Exposed dashboard
- Weak RBAC
- Service account abuse

Cloud Misconfigurations

- Public S3 buckets
- Leaked API keys
- IAM privilege escalation

Tools

- Trivy
- kube-hunter

10. Post Exploitation

Persistence

- SSH keys

- Cron jobs
- Backdoors

Data Exfiltration

- Credentials
- Database dumps
- Tokens

Lateral Movement

- SMB
- SSH pivoting
- Pass-the-Hash

Pivoting/Tunneling

- SSH Tunnel
- SOCKS Proxy
- Port Forwarding

Tools

- Chisel
- Ligolo-ng
- Metasploit Framework

11. Defense Evasion

Common Techniques

- Obfuscated payloads
- Living-off-the-land binaries
- Log deletion
- AMSI bypass
- AV evasion

12. Recommended Learning Path

Beginner

1. Linux basics
2. Networking fundamentals
3. Bash scripting

4. Web fundamentals
5. Basic enumeration

Intermediate

1. Web exploitation
2. Privilege escalation
3. Active Directory
4. Binary exploitation
5. Pivoting

Advanced

1. Kernel exploitation
2. Heap exploitation
3. Reverse engineering
4. Malware development
5. Cloud exploitation

Recommended Practice Platforms

Beginner Friendly

- [TryHackMe](#)
- [OverTheWire Bandit](#)

Intermediate

- [Hack The Box](#)
- [VulnHub](#)

Advanced

- [pwn.college](#)
- [PortSwigger Web Security Academy](#)